

Problem Set 3

PCC190 - Secure Machine Learning

Chapter 3: A Framework for Secure Learning

1. What is the stationarity assumption made by many machine learning methods? Why is this assumption central to the secure learning problem, and how can an attacker violate it more easily than natural nonstationarity would?
 - Definition: training data and evaluation data are drawn from the same (unknown) distribution $P_{\mathcal{Z}}$.
 - Under stationarity, minimizing the empirical risk on the training sample is a valid surrogate for minimizing the true risk on evaluation data.
 - Real-world data sources are often not stationary, so this assumption is fragile even without an adversary.
 - An attacker can break stationarity far more directly than natural drift does: with even partial control over training or evaluation instances, it can deliberately make $P_{\mathcal{Z}}^{(train)}$ and $P_{\mathcal{Z}}^{(eval)}$ diverge.
 - Analyzing and strengthening learning methods to withstand or mitigate such violations is the crux of the secure learning problem.
2. List the phases of the learning process that an attacker can target, as outlined in Section 3.1 (measuring, feature selection, learning model selection, training, prediction). Explain how an attack against the measuring phase differs from an attack against the training phase in terms of cost of recovery for the defender.
 - Measuring phase: attacker designs malicious instances that mimic the measurements of innocuous data.
 - Feature selection phase: attackable like the measuring phase, but cheaper to recover from since feature selection is dynamic and can be readapted, potentially even automatically; also attackable like the training phase if it depends on contaminated training data.
 - Learning model selection: attacker exploits erroneous or unreasonable modeling assumptions (e.g., assumed linear separability) to deceive the learner or degrade its performance.
 - Training phase: attacker designs data to make the learner choose a poor hypothesis, or to set up a later privacy breach during prediction.
 - Prediction phase: an imperfect hypothesis is exploited once deployed, by discovering its prediction errors.
 - Cost-of-recovery contrast: a successful attack on the measuring phase may require expensive re-instrumentation or redesign of the measurement apparatus itself; a training-phase attack is comparatively cheaper to recover from, since it mainly requires retraining (or hardening the training procedure), without redesigning how data is physically collected.
3. Define the Integrity goal, the Availability goal, and the Privacy goal of a security-sensitive classifier. For each goal, state whether it is more closely associated with false negatives, false positives, or neither.

Integrity goal: to prevent attackers from reaching system assets. Associated with *false negatives*: malicious instances that pass through the classifier can wreak havoc.

Availability goal: to prevent attackers from interfering with normal operation. Associated with *false positives*: the learner itself denies benign instances, causing a denial of service.

Privacy goal: to protect the confidentiality of potentially privacy-sensitive data used to train the classifier. Associated with *neither* FP nor FN as an end goal; an attacker breaching privacy may incidentally cause false positives or false negatives, but these are not what it is after.
4. The book assumes that the attacker and the defender each have a cost function. Explain the relationship assumed between these two cost functions, and explain the sentence: “the attacker and defender would not be adversaries if their goals aligned.”
 - Both attacker and defender have a cost function assigning a cost (positive or negative, a negative cost being a benefit) to each labeling of an instance, or to each training-instance privacy violation.
 - Assumed relationship (for ease of exposition, not essential to the framework): low cost for the attacker parallels high cost for the defender, and vice versa, i.e., every cost incurred by the defender corresponds to a similar benefit for the attacker.

- The framework extends easily to arbitrary, non-symmetric cost functions if needed.
 - The book adopts the defender's point of view: "high cost" means high positive cost for the defender.
 - The quoted sentence: what *defines* the two parties as adversaries is precisely that their cost functions point in opposite directions; if attacker and defender wanted the same outcome (aligned goals), there would be no conflict, and hence no adversarial relationship, by definition.
5. According to the threat model in Section 3.2.2, what does the attacker typically know about the training algorithm and the training data? What restrictions can limit the attacker's ability to generate or label arbitrary training instances?
- Threat model makes only weak assumptions on the adversary: the attacker is assumed to know the training algorithm, and in many cases has partial or complete information about the training set, such as its distribution.
 - Example: the attacker may be able to eavesdrop on all network traffic during the period the learner gathers training data.
 - In general the attacker is assumed able to generate arbitrary instances, but many settings restrict this in practice.
 - Restriction on labeling: sometimes the attacker cannot choose the label of injected training data (e.g., when training data is carefully hand labeled).
 - Restriction on generation: the attacker may fully control data at its own source, but routers or other intermediaries in transit may add to, alter, or reorder the data and affect its timing.
 - Restriction on extent of control: what fraction of the training data the attacker can influence, and to what degree, matters; 100% arbitrary control makes learning essentially hopeless (though some strategies still help), so the interesting cases are intermediate degrees of influence.
6. Present the three axes of the taxonomy of attacks against machine learning systems: INFLUENCE, SECURITY VIOLATION, and SPECIFICITY. For each axis, name its categories. Explain why the taxonomy yields at least 12 distinct classes of attacks.

INFLUENCE: • Causative attacks influence learning with control over training data.

• Exploratory attacks exploit predictions, but do not affect training.

SECURITY VIOLATION: • Integrity attacks compromise assets via false negatives.

• Availability attacks cause denial of service, usually via false positives.

• Privacy attacks obtain information from the learner, compromising the privacy of the learner's training data.

SPECIFICITY: • Targeted attacks focus on a particular instance.

• Indiscriminate attacks encompass a wide class of instances.

• Each axis operates independently of the others.

• Number of classes: 2 (Influence) $\times$ 3 (Security violation) $\times$ 2 (Specificity) = 12 distinct classes of attacks.

7. Formalize the Exploratory game: state the defender's move, the attacker's move, and the steps of the evaluation phase. What information can the attacker's procedure $A^{(eval)}$ use when constructing the evaluation distribution?

1. Defender: choose procedure $H^{(N)}$ for selecting a hypothesis.
2. Attacker: choose procedure $A^{(eval)}$ for selecting an evaluation distribution.
3. Evaluation:
 - Reveal distribution $P_Z^{(train)}$.
 - Sample dataset $D^{(train)}$ from $P_Z^{(train)}$.
 - Compute $f \leftarrow H^{(N)}(D^{(train)})$.
 - Compute $P_Z^{(eval)} \leftarrow A^{(eval)}(D^{(train)}, f)$.
 - Sample dataset $D^{(eval)}$ from $P_Z^{(eval)}$.
 - Assess total cost: $\sum_{(x,y) \in D^{(eval)}} \ell_x(f(x), y)$.
- Information available to $A^{(eval)}$: partial (or in some settings complete) knowledge of $D^{(train)}$ and of the classifier f (or of the family $\mathcal{F}$ containing f).

- $A^{(eval)}$ need not be static: it may query the classifier as an oracle for labels on chosen instances (a *probing attack*), adaptively refining the evaluation distribution as it learns more with each additional prediction.
8. How does the Causative game differ from the Exploratory game? Which new procedure does the attacker choose, and what part of the learning process does it allow the attacker to influence that the Exploratory attacker cannot?
- The attacker now chooses two procedures, $A^{(train)}$ and $A^{(eval)}$, instead of just $A^{(eval)}$.
 - Evaluation steps: compute $P_{\mathcal{Z}}^{(train)} \leftarrow A^{(train)}(P_{\mathcal{Z}}, H)$; sample $D^{(train)}$; compute $f \leftarrow H^{(N)}(D^{(train)})$; compute $P_{\mathcal{Z}}^{(eval)} \leftarrow A^{(eval)}(D^{(train)}, f)$; sample $D^{(eval)}$; assess the same total cost as in the Exploratory game.
 - New influence: $A^{(train)}$ lets the attacker affect the training distribution $P_{\mathcal{Z}}^{(train)}$, and therefore the training set $D^{(train)}$ itself.
 - In the Exploratory game the defender's classifier f is entirely outside the attacker's control (the attacker only ever chooses $D^{(eval)}$); in the Causative game the attacker has indirect influence over f as well, since f is trained on data the attacker helped shape.
 - This lets a Causative attacker proactively cause the learner to produce bad classifiers, rather than only reactively exploiting a classifier it cannot change.
9. Explain the difference between the direct (insertion) corruption model and the data alteration corruption model for an attacker's control over training data. Give one learning system discussed in the book that is analyzed under each model.

Direct (insertion) model: the attacker can insert new, arbitrary data points into the training set (subject to what fraction of the set it controls); used to analyze attacks on the SpamBayes spam filter in Chapter 5, where even a relatively small number of attack messages can significantly mislead the filter.

Data alteration model: the attacker can alter any (or all) of the existing data points, but only up to a limited degree of alteration; it cannot insert wholly new points, and the effectiveness of the attack is analyzed in terms of the size of alteration required.

- Example given: a detector monitoring network traffic volumes over time windows, where the attacker can add or remove some traffic but is restricted in how much, since each data point corresponds to a time slice shared with other (non-attacker) traffic sources; this is the model used for the PCA-subspace network anomaly detector analyzed in Chapter 6.

10. What are class limitations and feature limitations on an attacker's capabilities? Illustrate feature limitations using the email example given in Section 3.3.3.3.

Class limitations: restrictions on which class of instances (positive/malicious or negative/benign) the attacker is allowed to alter. Usually an external attacker can only create or manipulate positive (malicious) instances; an insider could in principle alter negative instances too, though this threat is not analyzed in the book (it is revisited in Chapter 9). In Privacy attacks there may be no natural class limitation, since the learner may not be classifying instances as malicious or benign at all.

Feature limitations: restrictions on how the attacker can alter each individual feature of a data point. Some features can be arbitrarily changed, others have stochastic aspects the attacker cannot fully control, and some cannot be altered at all.

- Email example: the attacker can completely control the content of the message, but cannot fully determine its routing or arrival time, and has no control over meta-information added to the message's header by mail relays while it is en route.

11. Using Example 3.1 (The Shifty Intruder), explain the difference between a Targeted and an Indiscriminate Exploratory Integrity attack.

- Setup: an attacker modifies and obfuscates intrusions (e.g., changing network headers, reordering or encrypting contents) so that the IDS fails to recognize the altered intrusions as malicious and lets them through, an Exploratory Integrity attack since the classifier itself is not retrained.
- Targeted version: the attacker already has one particular intrusion it needs to get past the filter, and the goal is to make that specific instance evade detection.

- Indiscriminate version: the attacker has no particular intrusion preference; it searches for any intrusion, among a large number of modified exploits, that succeeds in evading the filter.

12. Section 3.4.4.1 proposes defending against Exploratory attacks without probing by limiting information about training data, feature selection, and the hypothesis space or learning procedure. Briefly describe one concrete defense technique from each of these three strategies.

Training data: preventing the attacker from obtaining the training data limits its ability to reconstruct the classifier's internal state; in practice training data is rarely fully secret, so the attacker typically has only partial information, and this concern connects directly to privacy-preserving learning (Section 3.7).

Feature selection: choosing feature maps that are robust to the attacker's manipulations, e.g., a feature map based on character subsequences that resists obfuscation of words in spam emails (addition, deletion, or substitution of characters), or defenses against feature-deletion attacks that harden the choice of features against removal of high-value features from the evaluation data.

space / learning procedure: restricting the hypothesis space (e.g., via regularization) trades off generalization ability against susceptibility to attack; e.g., Anagram's use of high-order n -grams (n between 3 and 7) to resist mimicry attacks that only mimic normal traffic at the single-byte level, or Dalvi et al.'s cost-sensitive, game-theoretic naive Bayes classifier that anticipates the attacker's optimal feature changes and adjusts its likelihood function accordingly.

13. What is a probing attack? Define the ACRE-learning problem and explain what it means for a classifier to be ACRE-learnable.

- Probing attack: an Exploratory attack in which $A^{(eval)}$ queries the classifier as an oracle, treating its responses on chosen instances as information used to dynamically construct (or adapt) the evaluation distribution.
- ACRE-learning problem (Lowd & Meek): formalizes reverse engineering as the problem of finding, using a polynomial number of membership queries, a lowest-attacker-cost instance that the classifier labels negative; the attacker is assumed to know the feature space and to possess one positive and one negative example, but no general knowledge of the training data.
- ACRE-learnable: a classifier is ACRE-learnable if there exists a polynomial-query algorithm that finds a lowest-attacker-cost negative instance for it. Linear classifiers are shown to be ACRE-learnable under linear attacker cost functions, with some additional minor technical restrictions.

14. Describe the reject on negative impact (RONI) defense against Causative attacks. What quantity does it measure for a candidate training instance, and how does it decide whether to discard that instance?

- Purpose: a data sanitization technique that removes malicious instances from the training set before training.
- Step 1: train a classifier on a base training set.
- Step 2: add the candidate instance to the training set and train a second classifier.
- Step 3: apply both classifiers to a quiz set of instances with known labels.
- Quantity measured: the difference in accuracy on the quiz set between the classifier trained with and without the candidate instance, i.e., the instance's empirical negative impact on classification accuracy.
- Decision rule: if adding the candidate instance causes the resulting classifier to produce substantially more classification errors, the defender permanently removes it as detrimental; otherwise it is kept.

15. Kearns & Li's extension of PAC learning to maliciously contaminated training data shows that a learner cannot succeed once the attacker controls a fraction $\beta \geq \epsilon/(1 + \epsilon)$ of the training data. Explain what ϵ represents in this context and what the bound implies about the attacker's task as ϵ shrinks.

- In PAC learning, an algorithm succeeds if, with probability at least $1 - \delta$, it learns a hypothesis with at most probability ϵ of making an incorrect prediction on an example drawn from the same distribution; so ϵ is the target upper bound on the learner's error rate.
- Kearns & Li (1993) consider an attacker with arbitrary control over a fraction β of the training examples, and prove the learner cannot in general succeed once $\beta \geq \epsilon/(1 + \epsilon)$; for some classes of learners this bound is shown to be tight.

- As ϵ shrinks (the learner is required to achieve a stricter, lower error rate), the threshold $\epsilon/(1+\epsilon)$ shrinks as well, approaching 0.
- Implication: a learner that must be highly accurate can be defeated by an attacker controlling only a vanishingly small fraction of the training data; conversely, a learner that tolerates a larger error ϵ can withstand a proportionally larger contaminated fraction.

16. Define the breakdown point and the influence function of an estimator in the context of robust statistics. How do these two concepts relate to the security of a learning algorithm against Causative attacks?

- Gross-error model: $\mathcal{P}_\epsilon(F_{\mathcal{Z}}) \triangleq \{(1-\epsilon)F_{\mathcal{Z}} + \epsilon G_{\mathcal{Z}} \mid G_{\mathcal{Z}} \in \mathcal{P}_{\mathcal{Z}}\}$, a mixture of the true distribution $F_{\mathcal{Z}}$ with an unknown contaminating distribution $G_{\mathcal{Z}}$ at contamination rate ϵ .

Breakdown point ϵ^* : the smallest level of contamination at which the minimax asymptotic bias of the estimator becomes infinite, i.e., the largest fraction of contamination the estimator can tolerate before it can be made arbitrarily wrong.

Influence function: $\text{IF}(z; H, F_{\mathcal{Z}}) \triangleq \lim_{\epsilon \rightarrow 0} \frac{H((1-\epsilon)F_{\mathcal{Z}} + \epsilon \Delta_z) - H(F_{\mathcal{Z}})}{\epsilon}$, the scaled sensitivity of estimator H to an infinitesimal contamination placed at a single point z ; its worst case over z , $\gamma^*(H, F_{\mathcal{Z}}) \triangleq \sup_z |\text{IF}(z; H, F_{\mathcal{Z}})|$, is the gross-error sensitivity, finite when H is robust to infinitesimal point contamination.

- Relation to Causative security: a Causative attacker is effectively injecting a contaminating distribution into the training data, exactly the scenario the gross-error model captures. An estimator with a high breakdown point and a bounded influence function (low gross-error sensitivity) is inherently harder to mistrain, giving a principled, quantitative way to compare the robustness of candidate learning procedures against Causative attacks.

17. What distinguishes a repeated (iterated) learning game from the one-shot Exploratory and Causative games presented earlier in the chapter? Define regret, and explain what it means for the defender's worst-case regret R^* to be small relative to K .

- One-shot games (Sections 3.4.1, 3.5.1): defender and attacker each move exactly once, and cost is assessed a single time.
- Iterated game: players make K repetitions of the game; at each round k the defender receives predictions $\hat{y}^{(k,m)}$ from M experts, forms a composite prediction $\hat{y}^{(k)}$ via an update function $h^{(k)}$, then observes the true label $y^{(k)}$; the defender updates $h^{(k)}$ based only on past performance (regrets from the previous $k-1$ rounds), while the attacker retains essentially arbitrary control over the training data throughout.
- Instantaneous regret with respect to expert m : $r^{(k,m)} = \ell(\hat{y}^{(k)}, y^{(k)}) - \ell(\hat{y}^{(k,m)}, y^{(k)})$.
- Cumulative regret: $R^{(m)} \triangleq \sum_{k=1}^K r^{(k,m)}$, and worst-case regret $R^* \triangleq \max_m R^{(m)}$.
- Small R^* relative to K means the defender's composite (aggregation) strategy performs almost as well as the single best expert in hindsight, without having known in advance which expert would be best; if the average worst-case regret approaches 0 as $K \rightarrow \infty$ and the best expert has small risk, the composite predictor also achieves small risk.

18. State Definition 3.1 (ϵ -differential privacy). Explain, in your own words, what the definition guarantees when comparing a mechanism's responses on two neighboring databases.

- Setup: a database D is a sequence of rows $x^{(1)}, \dots, x^{(N)}$; a mechanism M releases only a response $M(D) \in \mathcal{T}_M$; two databases $D^{(1)}, D^{(2)}$ are neighbors if they differ in exactly one row.

Definition 3.1: for any $\epsilon > 0$, a randomized mechanism M achieves ϵ -differential privacy if, for all pairs of neighboring databases $D^{(1)}, D^{(2)}$ and all measurable subsets of responses $T \subseteq \mathcal{T}_M$,

$$\Pr [M(D^{(1)}) \in T] \leq \exp(\epsilon) \Pr [M(D^{(2)}) \in T].$$

- The probabilities are taken over the randomization of M alone, not over the databases, which are fixed.
- Interpretation: changing (or removing) any single row of the database can change the probability of any particular response by at most a multiplicative factor of $\exp(\epsilon)$; for $\epsilon \ll 1$ the mechanism's response distributions on any two neighboring databases are pointwise close, so an observer of M 's output cannot reliably tell whether any one individual's row was present, absent, or altered.

19. Section 3.7.2 describes a brute-force Exploratory privacy attack against a differentially private mechanism. Outline the three steps of this attack, and explain why it fails with high probability when ϵ is sufficiently small.

- Goal: recover the unknown last row $x^{(N)}$ of database D , with knowledge of M up to its randomness, knowledge of the first $N - 1$ rows, and unbounded computational resources.
- Step 1: for each candidate $\hat{x}^{(N)}$, form the neighboring database $D' = (x^{(1)}, \dots, x^{(N-1)}, \hat{x}^{(N)})$ and, offline, calculate its response distribution $p_{D'}$ of $M(D')$ by simulation.
- Step 2: estimate the true response distribution of $M(D)$ as $\hat{p}_D$ by querying the mechanism repeatedly, a number of times sublinear in N .
- Step 3: identify $x^{(N)} = \hat{x}^{(N)}$ for whichever candidate's $p_{D'}$ most closely resembles the estimated $\hat{p}_D$.
- Why it fails for small ϵ : ϵ -differential privacy bounds how much $p_{D'}$ can differ across neighboring databases, so for sufficiently small ϵ the true differences between candidate $p_{D'}$'s become extremely small; since $\hat{p}_D$ is only estimated from a sublinear number of queries, its sampling error will exceed these tiny true differences, so the matching step cannot reliably identify the correct candidate, and the attack fails with high probability.
 - The same robustness extends to the analogous Causative attack, where the adversary can arbitrarily manipulate the first $N - 1$ rows.

20. Describe one approach discussed in Section 3.7.3 for measuring the utility of a differentially private mechanism. Explain the fundamental tradeoff established by Dinur & Nissim (2003) between the accuracy of a mechanism's responses and the privacy it can guarantee.

- One approach (the book's own differentially private SVM work, Chapter 7): utility is defined as the pointwise closeness between the classifications produced by the released private classifier and those of the corresponding nonprivate SVM, both trained on D ; a private classifier that, with high probability, agrees with the nonprivate SVM on all test points is judged to be of high utility.
- Other approaches mentioned: closeness of released contingency-table marginals to the true marginals (Barak et al.); anonymized data on which a class of analyses yields results similar to the original data (Blum et al.); utility framed via PAC learning, averaging response and target concepts over the underlying measure (Kasiviswanathan et al.; Beimel et al.); utility measured by absolute error rather than approximation of a nonprivate target (Chaudhuri & Monteleoni; Chaudhuri et al.).
- Dinur & Nissim (2003) tradeoff: if noise of rate only $o(\sqrt{N})$ is added to subset-sum queries on a database D of N bits, an adversary can reconstruct a $1 - o(1)$ fraction of D .
- Implication: if a mechanism's responses are too accurate (too little noise), privacy cannot be guaranteed at all; this establishes a fundamental, unavoidable tradeoff between the accuracy/utility of a mechanism's released statistics and the level of privacy it can simultaneously provide.